

통 보

1. 제 목 : 정보 보안에 관한 사항
2. 관계기관 : ◻◻◻△△실, ◆◆○○○병원
3. 내 용

가. 업무개요

◆◆○○○병원은 원활한 병원 운영을 위해 EMR 등 다수 정보시스템을 운영하고 있으며, 이런 정보시스템을 통해 환자 및 방문객, 직원 등 개인정보를 수집·이용하고 있습니다.

나. 정보화 용역사업 보안성 검토에 관한 사항

1) 관계법령 및 판단기준

우리공단 「정보보안업무 처리지침」에 따르면 정보화 용역사업 추진 시에는 자체 보안대책을 수립·반영하고, 특히 아래 [표 1]에 해당하는 사업인 경우에는 보안대책의 적절성을 평가하기 위해 사업 계획단계(사업공고 전)에서 국가정보원장에게 보안성 검토를 의뢰하여야 한다고 정하고 있습니다.

[표 1] 정보보안업무 처리지침에 따른 보안성 검토 대상

- | |
|---|
| <ol style="list-style-type: none">1. 비밀 등 중요자료의 생산, 등록, 보관, 사용, 유통 및 재분류, 이관, 파기 등 비밀업무와 관련된 정보시스템 및 네트워크 구축2. 상용 암호모듈·정보보호시스템을 도입 운용하고자 할 경우3. 대규모 정보시스템(10억 이상 사업) 또는 다량의 개인정보(100만명 이상)를 처리하는 정보시스템 구축4. 내부 정보통신망을 인터넷이나 타 기관 전산망 등 외부망과 연동하는 경우5. 업무망과 연결되는 무선 네트워크 시스템 구축6. 스마트폰·클라우드 등 첨단IT기술을 업무에 활용하는 시스템 구축7. 업무망과 인터넷 분리 사업8. 그 밖에 각급기구의 장 또는 국가정보원장이 보안성 검토가 필요하다고 판단하는 정보화사업 |
|---|

또한 본사 ◻◻◻△△부 「정보화사업 추진 시 보안성검토 절차 안내」(◻◻◻-2037,

‘18.07.17.)에서는 정보시스템을 기획·구축·운영·유지보수하는 사업을 “정보화사업”으로 규정하고, 공단 내 모든 정보화사업 추진 시에는 본사 〰〰△△부에 보안성 검토를 의뢰하여 국가보훈처 및 국가정보원으로부터 사전 점검을 받도록 안내한 바 있습니다.

따라서 ◆◆○○병원에서는 정보시스템 구축 및 유지보수 용역 계약 등 정보화사업 추진 시, 본사 〰〰△△부에 보안성 검토를 의뢰하여 보안 취약점 사전 점검을 통해 보안대책 미비점을 보완하여 계약을 추진하여야 합니다.

2) 감사결과 확인된 문제점

그런데 ‘20~’21년 동안 ◆◆○○병원에서 추진한 정보화사업 내역을 확인한 결과, 아래 [표 2]와 같이 〰〰◆◆시스템 유지보수 용역 등 #건의 계약의 경우 설치·운영되는 시스템이 병원 정보시스템과 연동되어 보안성 검토 대상임에도, 담당자는 보안성 검토 대상, 절차 등을 인지하지 못하여 본사 〰〰△△부에 보안성 검토를 의뢰하지 않고 사업을 추진한 사실이 있습니다.

[표 2] ◆◆○○병원 정보화사업 추진 내역

순번	용역명	검토 대상 사유	사업부서	보안성검토
1	2020년 ▼▼▣▣●●시스템 유지보수 용역	&&&&&&&	▣▣부	X
2	2020년 〰〰〰〰▶▶▶▶ 시스템 유지보수 용역	&&&&&&&	◆◆◆부	X
3	〰〰〰〰●● 및 ○○◇◇◇◇◇ 유지보수 용역	&&&&&&&	◆◆◆부	X
4	○○▣▣병원 EMR 프로그램 유지보수 용역	&&&&&&&	◆◆○○부	O
5	◁◁◁ ▣▣▣▣ 관리시스템 임대	&&&&&&&	▣▣〰〰부	X
6	2021년 ○○○○ 〰〰〰〰 프로그램 유지보수	&&&&&&&	◆◆○○부	O
7	▣▣▣▣ 임차 용역	&&&&&&&	◆◆◆부	X
8	◀◀◀◀ ●●●● 용역	&&&&&&&	▣▣▣▣과	X
9	●●●● □□ 용역	&&&&&&&	◆◆◆부	X

다. 개인정보처리업무 위탁계약 관리에 관한 사항

1) 관계법령 및 판단기준

「개인정보 보호법」 제26조(업무 위탁에 따른 개인정보의 처리 제한) 및 같은 법 시행령 제28조(개인정보의 처리 업무 위탁 시 조치)에 따르면, 개인정보 처리자가 제3자에게 개인정보 처리 업무를 위탁할 경우에는 개인정보 처리, 보호 등에 대한 내용이 포함된 문서를 작성하도록 정하고 있습니다.

또한, ◆◆○○○○병원 「개인정보 보호지침」 제25조(업무위탁에 따른 개인정보의 처리 제한)에서는 개인정보 처리를 위탁하는 계약을 체결할 경우 개인정보 이용범위, 보호기준을 규정한 “표준 개인정보처리 위탁 계약서”를 작성하고, 계약종료 시에는 계약업체가 보유한 개인정보 파기 여부를 병원이 확인하도록 정하고 있습니다.

따라서, ◆◆○○○○병원에서는 고객 및 직원의 개인정보가 포함된 업무를 외부에 위탁할 경우에는 “표준 개인정보처리 위탁 계약서”를 작성하고, 계약종료 시에는 계약업체가 개인정보를 파기하였는지 여부를 확인하여야 할 것입니다.

2) 감사결과 확인된 문제점

그런데, ‘20~’21년 ◆◆○○○○병원 개인정보 위탁처리 계약 내역을 확인한 결과, 아래 [표 3]과 같이 개인정보 위탁처리가 이루어지는 총 ##건([별 표])의 계약 중 <<< ■■■■■ 관리시스템 임대 등 ##건의 계약에 대해 “표준 개인정보처리 위탁 계약서”를 작성하지 않았으며,

■■■■■■ 임차 용역 등 ##건은 계약 종료 후 계약업체가 보유한 ◆◆○○○○병원의 개인정보에 대해 파기 여부를 확인하지 않는 등 개인정보 보호관리가 미흡한 것으로 확인됩니다.

[표 3] ◆◆○○○○병원 개인정보 처리업무 위탁계약 관리현황

개인정보 위탁처리 계약 건수	표준개인정보처리 위탁계약서 작성	계약종료 건	
		파기 확인	파기 미확인
##	##	#	#

4. 관계기관 의견 : ◆◆○○○병원에서는 감사결과를 수용하고 별다른 의견을 제시하지 않았습니다.

5. 조치할 사항

○ ◆◆○○○병원장은

- 정보화사업 추진 시에는 본사 ▣▣▣△△부에 보안성 검토를 의뢰하시고,
- 개인정보 처리업무 위탁 계약과 관련하여 표준개인정보처리 위탁 계약서 작성 및 계약업체 개인정보 파기 여부를 확인하는 등 개인정보 보호 관리에 철저를 기하시기 바랍니다.(통보)

○ ○○이사는

- 정보화사업 추진 시 보안성 검토절차 등에 대해 '18. 7. 안내 후 재교육이 없어 보안성 검토대상 및 절차 등을 숙지하지 못하여 업무오류가 발생하고 있으므로, 소속기구에 주기적 안내 등을 통하여 정보화사업 추진 시 보안성 검토가 누락되지 않도록 하여 주시기 바랍니다.(통보)